

O que foi feito no código

Check Point 01 — DevSecOps (preparatório E|CDE, Módulo III) · Grupo 1
Repositório CP1_DEV_SEC_OPS · 12 de setembro de 2026

Registro parcial do trabalho de código: pipeline, gate de severidade, as duas correções de remediação e os scripts de apoio. Não cobre o documento de pesquisa da seção 6, o vídeo nem a apresentação.

1. Correções no código existente

O que foi corrigido	Como ficou
Build vermelho não era mais reproduzível — o pipeline aplicava as duas correções em toda execução	Entrada booleana <code>remediacao</code> no <code>workflow_dispatch</code> . Desmarcada, reproduz o estado vulnerável. O job de DAST confere as duas direções
Gate de DAST testava só o campo <code>msg</code> ; na Nikto 2.5.0 o caminho ficou só em <code>url</code> , e 4 dos 7 padrões de <code>NIKTO_HIGH</code> não casavam com nada	Passou a testar <code>url + msg</code> . Conferido: 2 achados antes e 2 depois, sem alterar nenhum número publicado
Guarda de escopo deixava passar uma porta pública acrescentada ao lado do <code>bind 127.0.0.1</code>	Virou <code>scripts/verificar-escopo.sh</code> , usado pelo CI e pelo deploy. Exige <code>host_ip = 127.0.0.1</code> em toda porta publicada
<code>patches/fix-sqli.php</code> usava <code>\$_DVWA['SQLI_DB']</code> , que não existe no DVWA 1.9 da imagem: a página quebrava e a consulta legítima devolvia 0 linha	Reescrito para detectar a versão do DVWA e acumular em <code>\$html</code> . Um arquivo serve para a imagem e para o DVWA que o CI clona
Números da documentação em desacordo com os relatórios (passo 2 e passo 5 do <code>LAB.md</code> ; "PDO" no <code>DEPLOY.md</code>)	Substituídos pelos valores contados nos relatórios versionados
Repositório sem <code>.gitignore</code> : um <code>git add .</code> levaria o DVWA, TerraGoat e NodeGoat para dentro do trabalho	Criado, cobrindo <code>targets/</code> , chaves privadas e lixo de editor. Os relatórios seguem versionados

O gate passou a imprimir a tabela de contagem na aba **Summary** da execução — é de onde sai o print do build vermelho e do verde.

2. Arquivos criados

Arquivo	Para que serve
<code>scripts/verificar-escopo.sh</code>	Guarda de escopo da seção 7, usada pelo CI e pelo deploy
<code>scripts/rodar-sca-iac.sh</code>	Roda Terrascan e Snyk nos alvos autorizados, medindo o tempo de cada um
<code>scripts/resumir-achados.py</code>	Lê os quatro formatos de relatório e gera a tabela da seção 6(e)
<code>scripts/testar-sqli.py</code>	Bateria de payloads contra a página de SQLi, para provar a correção na aplicação em execução
<code>.gitignore</code>	Mantém <code>targets/</code> e chaves privadas fora do repositório
<code>reports/README.md</code>	O que cada relatório contém, com os números conferidos
<code>evidencias/execucao-local-2026-09-12.md</code>	A execução local completa, reproduzível
<code>VIBE.md</code>	Registro do trabalho de código, com o motivo de cada mudança
<code>CLAUDE.md</code> e <code>.claude/</code>	Contexto do projeto e as regras que não se negociam

3. Execuções e resultados

Docker Engine 29.7.2, containers Linux, tudo em `127.0.0.1`. Nenhum alvo fora da lista autorizada da seção 7. Ambiente derrubado ao final com `docker compose down -v`.

3.1 Gate rodado nas duas pontas, com os programas jq do próprio workflow

Métrica	Sem remediação	Com remediação
OpenGrep — achados totais	58	56
OpenGrep — nível error	25	23
OpenGrep — error em vulnerabilities/sqli/ (o que o gate conta)	2	0
Nikto — itens reportados	15	12
Nikto — na lista NIKTO_HIGH (o que o gate conta)	2	0
Decisão do gate	REPROVADO (total 4)	APROVADO (total 0)

A varredura sem patch reproduz o SARIF versionado achado por achado.

3.2 Correção do SQL Injection verificada na aplicação em execução

Payload	Antes	Depois
1 (legítimo)	1 linha	1 linha
999 (inexistente)	0	0
1' OR '1'='1	5 — tabela inteira	1
' OR '1'='1	5 — tabela inteira	0
1' OR 1=1 --	5 — tabela inteira	1
1' UNION SELECT user, password FROM users --	6	1
'	erro de SQL vazando	0

Zero notices de PHP vindos de low.php depois da correção. As 1 linha que restam em dois payloads não são injeção: o MySQL compara a coluna inteira user_id com a string recebida e converte o prefixo numérico para 1. A prova é ' OR '1'='1, sem dígito no início, que devolve 0.

3.3 Correção do directory indexing verificada

Estado	/config/	/docs/
sem docker-compose.hardening.yml	HTTP 200, com Index of /config	HTTP 200, listagem exposta
com o override (Options -Indexes)	HTTP 403	HTTP 403

3.4 Terrascan (IaC) executado — primeira execução da ferramenta

Alvo TerraGoat, 494 políticas validadas, **67 violações**: 35 HIGH, 27 MEDIUM, 5 LOW. Por provedor: AWS 42, Azure 14, GCP 11. Relatório em reports/terrascan-terragoat.json.

3.5 Tempos de execução medidos (seção 6e)

Ferramenta	Alvo	Tempo	Achados
OpenGrep 1.22.0	DVWA — 250 arquivos, 126 regras	31 s	58 (25 error, 33 warning)
Nikto 2.5.0	DVWA no ar — 7857 requisições	6 s	15 itens
Terrascan	TerraGoat — 494 políticas	10 s	67 (35 H, 27 M, 5 L)

Valores em reports/tempos.txt, recontáveis com python3 scripts/resumir-achados.py.

3.6 Guarda de escopo testada contra casos de exposição

Caso	Versão anterior	Versão atual
arquivo inalterado	passa	passa
- "8081:80"	reprova	reprova — nomeia dvwa: 0.0.0.0:8081

Caso	Versão anterior	Versão atual
- "0.0.0.0:8081:80"	reprova	reprova
- "192.168.0.10:8081:80"	reprova	reprova — nomeia o IP
porta pública acrescentada ao lado do bind local	passa	reprova — dvwa: 0.0.0.0:9090
porta do DVWA trocada para 8082	reprova	reprova — a documentação assume 8081

4. Evidência versionada

O pacote em `reports/` passou de 3 para 7 arquivos, cobrindo o antes e o depois de cada correção.

Arquivo	Ferramenta	Estado
<code>opengrep-dvwa.sarif</code>	OpenGrep (SAST)	antes da remediação
<code>opengrep-dvwa-remediado.sarif</code>	OpenGrep (SAST)	depois — novo
<code>nikto-dvwa.json / .txt</code>	Nikto (DAST)	antes da remediação
<code>nikto-dvwa-remediado.json</code>	Nikto (DAST)	depois — novo
<code>terrascan-terragoat.json</code>	Terrascan (IaC)	TerraGoat — novo
<code>tempos.txt</code>	todas	tempo de cada execução — novo
<code>resumo-achados.md</code>	todas	tabela da seção 6(e), gerada — novo

5. Documentos atualizados

Documento	O que mudou
<code>LAB.md</code>	Saída real do passo 2; tabela do passo 5 com os números conferidos e como reproduzir o vermelho; verificação das duas correções; nota sobre a divergência de versão do Nikto; checklist de publicação
<code>DEPLOY.md</code>	Comportamento do gate com a chave <code>remediacao</code> ; resultado esperado das duas execuções; "PDO" corrigido para prepared statement com <code>mysqli</code> ; troubleshooting
<code>README.md</code>	Árvore de arquivos; tabela de ferramentas com o Terrascan executado; como reproduzir o build vermelho
<code>USO-DE-IA.md</code>	Declaração da revisão, exigida pela seção 10, com seis erros de material gerado por IA registrados — incluindo uma suposição da própria revisão que a execução desmentiu
<code>reports/README.md</code> , <code>evidencias/README.md</code>	O que cada relatório contém e de onde sai cada print

Registro completo, com o motivo de cada mudança, em `VIBE.md`. Todos os números foram contados nos relatórios de `reports/`.